1. Threat Hunting Methodologies

Core Concepts

Proactive Threat Hunting

- It is hypothesis-driven
- Analysts assume a possible attack and search for evidence
- Example: Detect misuse of valid accounts (T1078) by analyzing login logs

Difference:

- Proactive → Find threats before alerts
- Reactive → Respond after alert

Hunting Frameworks

1. SqRR (Search, Query, Retrieve, Respond)
    - Search → Identify suspicious activity
    - Query → Run queries on logs
    - Retrieve → Collect relevant data
    - Respond → Take action
2. TaHiTI (Targeted Hunting integrating Threat Intelligence)
    - Combines threat intelligence + hunting
    - Focuses on known attacker techniques (TTPs)

Data Sources for Hunting

Threat hunting uses multiple data sources:

- EDR logs → Endpoint activity
- Network traffic → Suspicious connections
- System logs → Login, privilege changes
- Threat intelligence feeds → Known malicious IPs, hashes

Key Objectives

- Identify hidden threats early
- Detect advanced attacks (APT, insider threats)
- Improve security monitoring
- Reduce response time

2. Advanced SOAR Automation

Core Concepts

- SOAR Components

  - **Orchestration**
    → Integrates multiple security tools into a single workflow
    (Example: SIEM + EDR + Threat Intelligence)

  - **Automation**
    → Performs tasks automatically without human intervention
    (Example: auto-ticket creation, IP reputation check)

  - **Response**
    → Takes action to mitigate threats
    (Example: blocking malicious IP, isolating system)

- Playbook Development

  - Playbooks are **predefined automated workflows** for handling incidents
  - Designed for common threats like:
    - Phishing
    - Malware
    - Unauthorized access

  Example:

  phishing playbook → Detect email → Check IP → Block IP → Create ticket

- Integration with SIEM/EDR

SOAR integrates with tools like:

- **SIEM (Wazuh, Elastic)** → for alerts
- **EDR** → for endpoint data

Benefit:

- Smooth data flow
- Faster detection and response

Key Objectives

- Automate repetitive SOC tasks
- Reduce response time (MTTR)
- Improve efficiency and accuracy
- Ensure consistent incident handling

3. Post-Incident Analysis and Continuous Improvement

Post-incident analysis is the process of reviewing a security incident after it occurs to identify its cause, evaluate the response, and improve future security measures. It helps organizations strengthen their SOC operations and prevent similar incidents.

Core Concepts

- Root Cause Analysis (RCA)
  - Used to identify the **actual cause of an incident**
  - Common techniques:
    - **5 Whys** → Asking "why" repeatedly to find root cause
    - **Fishbone Diagram** → Categorizing causes (People, Process, Technology, Environment)

  Example: Phishing attack → Weak email filtering → Lack of security controls

- Lessons Learned Process
  - Conducted after incident resolution
  - Helps improve:

    - Security policies
    - Tools and technologies
    - User awareness and training
- Metrics and KPIs

  - **MTTD (Mean Time to Detect)**
  → Time taken to detect a threat

  - **MTTR (Mean Time to Respond)**

- Key Objectives

  - Identify root causes of incidents

  - Improve detection and response

  - Enhance security controls

  - Enable continuous improvement

4. Adversary Emulation Techniques

Adversary emulation is the process of **simulating real-world attacker behaviors (TTPs)** to test the effectiveness of security systems. It helps evaluate how well a SOC can detect and respond to cyberattacks.

- Core Concepts
    - Adversary Emulation

        - Simulates attacker techniques based on **MITRE ATT&CK**
        - Uses real attack patterns like:

            - **T1566** → Phishing
            - **T1210** → Exploitation of Remote Services

        Example: Simulating a phishing attack to test email security and detection systems.

    - Emulation Frameworks
        - Tools used for automated attack simulation

- Example:
    - **MITRE Caldera**
      → Simulates attacks and maps them to ATT&CK techniques

- Benefits:

    - Tests detection capabilities

    - Identifies security gaps

- Red-Blue Team Collaboration
    - **Red Team** → Simulates attacker
    - **Blue Team** → Defends and detects
    - Emulation helps:
        - Improve detection rules
        - Strengthen defense strategies

- Key Objectives
    - Test SOC detection and response
    - Identify security weaknesses
    - Improve monitoring and alerts
    - Validate security controls

5. Security Metrics and Executive Reporting

Security metrics and executive reporting are used to **measure SOC performance** and communicate security status to management. These metrics help identify weaknesses and improve overall cybersecurity effectiveness.

Core Concepts

- Advanced SOC Metrics
    - **Dwell Time**
      → Time between attack and detection
    - **False Positive Rate**
      → Percentage of alerts that are not real threats
    - **Incident Resolution Rate**
      → Number of incidents successfully resolved
- Executive Reporting
    - Present security data to **non-technical stakeholders**
    - Use:
        - Simple language
        - Charts / summaries
        - Clear conclusions

- Continuous Improvement
    - Metrics help identify gaps:
        - High MTTD → Slow detection
        - High false positives → Poor alert quality

    Improvements:

        - Better tools
        - Automation
        - Staff training

- Key Objectives
    - Measure SOC performance
    - Improve detection and response
    - Communicate effectively with leadership
    - Support decision-making